

SOC INTERNSHIP PROGRAM

Project: Detection Engineering Assessment

Case 1: Malicious PowerShell Download Attack

Executive Summary

A suspicious PowerShell execution was detected on an endpoint where PowerShell was used to download and execute an external payload. Attackers commonly abuse PowerShell because it is a legitimate Windows tool and can bypass traditional security controls.

This detection focuses on identifying malicious scripting activity, unauthorized command execution, and possible malware delivery attempts.

Risk Level: High

Impact: Possible malware infection, remote access, and system compromise.

MITRE ATT&CK Mapping

Technique	ID
Command and Scripting Interpreter: PowerShell	T1059.001
Ingress Tool Transfer	T1105
User Execution	T1204

Required Log Sources

- Windows Event Logs
- PowerShell Operational Logs
- Sysmon Event ID 1 (Process Creation)
- Sysmon Event ID 3 (Network Connection)
- EDR Telemetry
- Proxy Logs

Detection Logic

- PowerShell executes with encoded commands
- PowerShell connects to external IP addresses
- PowerShell downloads executable files

Alert Severity

High

Reason:

- Potential malware execution

- Possible command execution by attacker

False Positives

- Administrator automation scripts
- Software deployment tools
- Security testing activities

SOC Response Actions

Isolate affected endpoint

- Review PowerShell command history
- Identify downloaded files
- Check persistence mechanisms
- Remove malicious files
- Perform malware scan

Detection Workflow

User Opens Malicious File

|

↓

PowerShell Execution

|

↓

Log Collection

|

↓

Suspicious Command Detected

|

↓

SIEM Alert Generated

|

↓

SOC Investigation

|

↓

Endpoint Containment

Tuning Recommendations

- Maintain approved PowerShell script list
- Enable PowerShell Script Block Logging
- Whitelist trusted administrative tools
- Monitor privileged user activity

Final SOC Recommendation Report

The SOC should maintain continuous monitoring of PowerShell activity because attackers frequently use legitimate scripting tools during attacks.

Recommended actions:

- Enable advanced PowerShell logging on all endpoints.
- Integrate PowerShell events with SIEM correlation rules.
- Deploy EDR monitoring for command execution.
- Perform regular threat hunting for PowerShell abuse.
- Review PowerShell alerts monthly to reduce false positives.

Case 2: External Brute Force Login Attack

Executive Summary

Multiple failed authentication attempts were detected against a remote access service. The activity indicates a possible brute force attack where an attacker attempts to guess valid credentials.

Successful exploitation may lead to unauthorized account access and further attacks inside the organization.

Risk Level: High

Impact: Account compromise and unauthorized access.

Detection Details

MITRE ATT&CK Mapping

Technique	ID
Brute Force	T1110
Password Guessing	T1110.001
External Remote Services	T1133

Required Log Sources

- VPN Authentication Logs
- Active Directory Logs
- Firewall Logs

- Identity Provider Logs

Detection Logic

Alert when:

20+ failed login attempts
from same source IP
within 10 minutes

Alert Severity

High

False Positives

- User password mistakes
- Forgotten passwords
- VPN configuration issues

Response Actions

1. Block malicious IP
2. Check successful logins
3. Reset compromised passwords
4. Enable MFA
- 5. Investigate affected accounts**

Detection Workflow

Failed Login Attempts

|

↓

Threshold Analysis

|

↓

Suspicious Pattern Detected

|

↓

SOC Alert



Account Investigation

Tuning Recommendations

- Apply different thresholds for privileged users
- Use geo-location analysis
- Integrate threat intelligence feeds

Final SOC Recommendation Report

The SOC should strengthen authentication monitoring and reduce credential-based attacks.

Recommended actions:

- Enforce Multi-Factor Authentication.
- Monitor privileged accounts separately.
- Implement account lockout policies.
- Detect impossible travel login patterns.
- Review authentication alerts regularly.

Case 3: Unauthorized Administrator Privilege Assignment

Executive Summary

An unauthorized privilege modification was detected where a standard user account received administrative permissions.

Privilege escalation allows attackers to gain higher access and perform malicious activities such as lateral movement and data theft.

Risk Level: Critical

Impact: Full system compromise.

Detection Details

MITRE ATT&CK Mapping

Technique	ID
Account Manipulation	T1098

Technique	ID
Valid Accounts	T1078
Privilege Escalation	TA0004

Required Logs

- Active Directory Logs
- Windows Security Logs
- Identity Management Logs
- EDR Logs

Detection Logic

Alert when:

- User added to Administrator group
- New privileged account created
- Unexpected permission changes occur

Alert Severity

Critical

False Positives

- Approved IT changes
- Employee onboarding
- System administration

Response Actions

1. Verify authorization
2. Remove unauthorized privileges
3. Disable suspicious account
4. Investigate activity history

Detection Workflow

Privilege Change

|

↓

Approval Verification

|

↓

Unauthorized?

|

↓

Critical Alert

|

↓

Contain Account

Tuning Recommendations

- Integrate change management records
- Monitor privileged accounts
- Create alerts for unusual admin activity

Final SOC Recommendation Report

The SOC should prioritize privilege monitoring because unauthorized administrative access can lead to complete infrastructure compromise.

Recommended actions:

- Implement Privileged Access Management (PAM).
- Monitor all administrator group changes.
- Require approval for privilege escalation.
- Perform regular access reviews.

Case 4: Cloud Data Exfiltration Attempt

Executive Summary

A potential cloud data exfiltration attempt was detected when a large volume of sensitive organizational data was transferred from an internal system to an unauthorized external cloud storage service.

Attackers or malicious insiders may use cloud platforms to move stolen data outside the organization while avoiding traditional network-based detection. This detection focuses on identifying unusual outbound data transfers, unauthorized cloud usage, and possible data theft activities.

Risk Level: Critical
Impact: Confidential data exposure, compliance violations, financial loss, and reputational damage.

MITRE ATT&CK Mapping

Technique	Technique ID	Description
Exfiltration Over Web Service	T1567	Data stolen using web-based services
Exfiltration Over Web Service: Exfiltration to Cloud Storage	T1567.002	Uploading data to cloud storage platforms
Automated Exfiltration	T1020	Automated movement of collected data

Required Log Sources

Network Logs

- Firewall Logs
- Proxy Logs
- NetFlow Logs
- DNS Logs

Endpoint Logs

- EDR Telemetry
- File Access Logs
- Process Monitoring Logs

Cloud Security Logs

- Cloud Access Security Broker (CASB)
- Cloud Application Logs
- Storage Access Logs

Identity Logs

- Active Directory Logs
 - Identity Provider Logs
 - User Authentication Logs
-

Detection Logic

Generate an alert when multiple suspicious conditions occur:

Rule 1: Large Outbound Data Transfer


```
IF outbound_data_size > normal_user_baseline
AND destination = unknown_cloud_service
THEN generate alert
```

Rule 2: Sensitive File Upload

```
IF sensitive_file_access
AND external_upload_detected
THEN create critical alert
```

Rule 3: Abnormal User Behaviour

```
IF user uploads data outside working hours
AND destination is unauthorized
THEN trigger investigation
```

Detection Indicators

Indicator	Example
Large data upload	500GB uploaded within 30 minutes
Unknown cloud service	New external storage domain
Unusual timing	Activity at 2 AM
Sensitive files accessed	Customer database, financial records
Abnormal user behaviour	First-time cloud upload

Alert Severity

Critical

Reason:

- Possible data breach
- Sensitive information exposure
- Regulatory impact
- Insider threat possibility

False Positives

Possible legitimate activities:

- Approved cloud backup operations
- Business file sharing
- Software update downloads
- Migration activities
- Authorized third-party collaboration

SOC Response Actions

Immediate Actions

1. Validate user activity.
2. Block unauthorized cloud destination.
3. Stop ongoing data transfer.
4. Preserve logs and evidence.
5. Notify incident response team.

Investigation Steps

1. Identify user account involved.
2. Review accessed files.
3. Check authentication history.
4. Determine data classification.
5. Identify affected systems.

Recovery Actions

- Remove unauthorized access.
- Reset compromised credentials.
- Apply data protection controls.
- Document incident findings.

Detection Workflow

User Accesses Sensitive Data

|

↓

File Monitoring Detects Access

|

↓

Outbound Transfer Begins

|

↓

Network Monitoring Analysis

|

↓

Unauthorized Cloud Destination Found

|

↓

SIEM Generates Critical Alert

|

↓

SOC Investigation

|

↓

Block Transfer / Contain Account

|

↓

Incident Response

Tuning Recommendations

1. Establish normal user data transfer baselines.
2. Maintain an approved cloud application whitelist.
3. Integrate DLP policies with SIEM.
4. Monitor privileged user activity separately.
5. Use User and Entity Behavior Analytics (UEBA).
6. Reduce false alerts by excluding known backup systems.
7. Review cloud access permissions regularly.

Final SOC Recommendation Report

The SOC should strengthen data loss prevention capabilities by combining network monitoring, cloud security monitoring, and user behavior analytics.

Recommended improvements:

1. Deploy Data Loss Prevention (DLP) solutions to detect sensitive data movement.
2. Implement Cloud Access Security Broker (CASB) monitoring for unauthorized cloud usage.
3. Integrate cloud activity logs with SIEM platforms.
4. Apply least privilege access controls for sensitive information.
5. Enable automated blocking for high-risk data transfers.
6. Conduct regular data access reviews.
7. Perform threat hunting for unusual outbound communication patterns.]

Case 5: Ransomware Encryption Activity

Executive Summary

A ransomware encryption activity was detected on an endpoint where a large number of files were modified, encrypted, or renamed within a short period. The attacker attempted to make organizational data unavailable and may have disabled recovery mechanisms to increase the impact of the attack.

Ransomware attacks can cause significant operational disruption, financial loss, and data compromise. This detection focuses on identifying abnormal file encryption behavior, ransomware execution patterns, and system recovery manipulation.

Risk Level: Critical

Impact: Data unavailability, business disruption, potential data loss, and ransomware infection spread.

MITRE ATT&CK Mapping

Technique	Technique ID	Description
Data Encrypted for Impact	T1486	Encrypting data to disrupt availability
Inhibit System Recovery	T1490	Deleting backups and recovery options
File and Directory Discovery	T1083	Searching for valuable files
Service Stop	T1489	Stopping services before encryption

Required Log Sources

Endpoint Logs

- EDR Telemetry
- Antivirus Logs
- Sysmon Logs
- Windows Security Logs
- File Integrity Monitoring Logs

File System Logs

- File Server Logs
- NAS Storage Logs
- Share Access Logs

System Logs

- Windows Event Logs
- Backup System Logs
- Process Creation Logs

Detection Logic

Rule 1: Mass File Encryption Detection

Trigger alert when:

More than 500 file modifications
within 5 minutes
from a single endpoint

Rule 2: Suspicious File Extension Changes

Detect:

Multiple files renamed with unknown extensions

Example:

.docx → .locked

.xlsx → .encrypted

.pdf → .crypt

Rule 3: Recovery Destruction Detection

Alert when:

vssadmin delete shadows

OR

wbadmin delete catalog

Example:

vssadmin.exe delete shadows /all

Detection Indicators

Indicator	Example
High file modification rate	Thousands of files changed quickly
Unknown extensions	.encrypted, .locked
Suspicious processes	Unknown encryption executable
Backup deletion	Shadow copies removed
Security service shutdown	Antivirus disabled

Alert Severity

Critical

Reason:

- Active ransomware infection
 - Potential business shutdown
 - Data availability impact
 - Possible lateral spread
-

False Positives

Possible legitimate activities:

- Large software installation
 - Database migration
 - Backup restoration
 - File synchronization tools
 - Authorized bulk file processing
-

SOC Response Actions

Immediate Response

1. Isolate affected endpoint from network.
 2. Stop malicious processes.
 3. Disable compromised user accounts.
 4. Block ransomware indicators.
 5. Prevent lateral movement.
-

Investigation Steps

1. Identify the first infected system.
 2. Determine ransomware family.
 3. Analyze malware samples.
 4. Check affected files.
 5. Review user activity.
 6. Identify attack entry point.
-

Recovery Actions

1. Restore data from clean backups.
2. Remove ransomware persistence.
3. Reset compromised credentials.
4. Patch exploited vulnerabilities.

5. Monitor environment for reinfection.

Detection Workflow

Suspicious File Activity Detected

|

↓

File Modification Rate Analysis

|

↓

Encryption Pattern Identified

|

↓

Check Ransomware Indicators

|

↓

SIEM Generates Critical Alert

|

↓

SOC Investigation

|

↓

Endpoint Isolation

|

↓

Incident Recovery Process

Tuning Recommendations

1. Establish normal file modification baselines.
2. Exclude approved backup and migration systems.
3. Monitor encryption behavior rather than only file extensions.
4. Integrate EDR ransomware prevention features.
5. Create automated endpoint isolation rules.
6. Maintain updated ransomware indicators.
7. Regularly test backup restoration procedures.

Final SOC Recommendation Report

The SOC should implement a layered ransomware defense strategy combining prevention, detection, response, and recovery capabilities.

Recommended Actions:

1. Deploy advanced EDR solutions with ransomware behavior detection.
2. Enable real-time file monitoring on critical servers.
3. Maintain offline and immutable backups.
4. Implement network segmentation to limit ransomware spread.
5. Monitor privileged accounts for suspicious activity.
6. Conduct regular ransomware simulation exercises.
7. Automate containment actions through SOAR platforms.
8. Perform continuous threat hunting for ransomware indicators.